

INCIDENT RESPONSE PLAN

1.Incident Classification & Severity

Severity	MTTR Target	Example Triggers
P1 - CRITICAL	< 1 Hour	Active data breach, ransomware, root compromise, complete service outage
P2 - HIGH	< 4 Hours	Unauthorized IAM access, public S3 exposure, GuardDuty critical finding
P3 - MEDIUM	< 24 Hours	Failed login spike, Security Group change, suspicious API calls
P4 - LOW	< 72 Hours	Policy violation detected, unusual read pattern, minor config drift

2.Incident Detection & Alerting

Source	What It Detects	Delivery
CloudWatch - Root Account Access filter	Any root account API call or console login	SNS > Email
CloudWatch - Unauthorized API Calls filter	Access denied spike (>= 10 in 5 min)	SNS > Email
CloudWatch - IAM Role Change filter	Role creation, deletion, policy attach/detach	SNS > Email
CloudWatch - Failed Login filter	Repeated console login failures (>= 3 in 5 min)	SNS > Email
CloudWatch - Security Group Change filter	Any SG rule addition, removal, or deletion	SNS > Email
CloudWatch - CPU / Network anomaly	Web server CPU > 80% or network > 500 MB in 5 min	SNS > Email
CloudTrail	Full audit log of all AWS API calls - passive audit	S3 + CloudWatch Logs
Manual Report	User or developer reports suspicious behaviour	Email / Slack

3.Incident Response Phases

Phase 1:IDENTIFICATION

Actions:

1. Acknowledge the SNS/CloudWatch alert - log time of first awareness
2. Open CloudTrail Event History - filter by event time and affected resource
3. Run CloudWatch Logs Insights query to find all related events in the window
4. Identify: source IP, IAM principal, affected services, data potentially exposed
5. Check VPC Flow Logs for any outbound connections to unusual IPs
6. Assign severity: P1 / P2 / P3 / P4
7. Open Incident Ticket - record all findings with timestamps

Phase 2:CONTAINMENT

Short-Term Containment:

1. If compromised IAM user/role detected - immediately deactivate access keys via AWS CLI or Console
2. If EC2 instance shows signs of compromise - isolate it: attach a restrictive isolation Security Group (deny all inbound/outbound except forensic admin)
3. If S3 bucket exposed publicly - set Block Public Access immediately
4. If root account compromise suspected - change root password and revoke all root access keys
5. Enable CloudTrail log file validation to ensure log integrity during investigation

Long-Term Containment:

- Snapshot the affected EC2 instance volume for forensic analysis before any changes
- Disable the affected IAM user account entirely (do not delete but preserve for forensics)
- If KMS key suspected compromised - disable the key; do not delete (30-day waiting period)
- Rotate all potentially exposed secrets in SSM Parameter Store
- Notify cloud team to monitor for lateral movement to other instances

Phase 3:ERADICATION

Goals:

1. Identify the exact attack vector from forensic analysis (CloudTrail, Flow Logs, system logs)
2. Terminate the compromised EC2 instance - rebuild from a clean, verified AMI snapshot
3. Delete or revoke all IAM credentials associated with the breach
4. Remove any unauthorised IAM policies, roles, or users the attacker may have created
5. Patch the vulnerability that allowed initial access (CVE, misconfiguration, weak password)
6. Scan all other EC2 instances for similar indicators of compromise (same malware signature, same IP in flow logs)
7. Rotate ALL KMS keys that could have been accessed during the incident window
8. Rotate all SSM SecureString parameters (DB passwords, API keys) proactively
9. Verify CloudTrail has continuous, unbroken logs for the entire incident window

Phase 4:RECOVERY

Recovery Steps:

1. Deploy rebuilt EC2 instance from a clean, hardened AMI into the same VPC/subnet
2. Restore application data from the last verified clean S3/RDS backup
3. Reattach the correct Security Groups - verify inbound/outbound rules match IRP design
4. Create new IAM user accounts with fresh credentials for affected users
5. Verify encryption - confirm new EBS volumes are encrypted with KMS CMK
6. Run a full IAM credential report - ensure no stale or unknown access keys exist
7. Perform smoke-testing: confirm web server accessible, DB only accessible from app tier
8. Confirm all 5 CloudWatch metric filter alarms are in OK state with no active breaches
9. Monitor the environment at elevated frequency for 48 hours post-recovery
10. Declare incident resolved only when Incident Commander signs off

Phase 5:POST-INCIDENT REVIEW

Agenda:

1. Timeline reconstruction - minute-by-minute from first alert to resolution
2. Root cause analysis - what control failed? Why? (misconfiguration, missing policy, zero-day)
3. Detection gap analysis - how long between incident start and first alert?
4. Response gap analysis - what slowed containment or eradication?
5. Action items - concrete changes to prevent recurrence, with owner and due date

4.Incident Playbooks

Compromised IAM Credentials

Step	Action	AWS Service
1. Detect	Unauthorized API Calls alarm fires; CloudTrail shows unfamiliar source IP	CloudWatch / CloudTrail
2. Identify	Determine which IAM user/role is involved; pull full event history	CloudTrail Event History
3. Contain	Deactivate access keys; attach deny-all inline policy to user	IAM Console / CLI
4. Preserve	Export all CloudTrail events for the user as forensic evidence	CloudTrail / S3
5. Eradicate	Delete all keys; check for new IAM entities the attacker may have created	IAM
6. Recover	Issue new credentials; enforce MFA; notify affected user	IAM
7. PIR	Determine how credentials were exposed (phishing, hardcoded in code, etc)	-

Publicly Exposed S3 Bucket

Step	Action	AWS Service
1. Detect	CloudWatch alert or AWS Trusted Advisor flags public bucket access	CloudWatch / Trusted Advisor
2. Identify	List objects in bucket; determine what data was potentially exposed	S3 Console / CLI
3. Contain	Immediately apply Block Public Access on the bucket	S3 Console / CLI
4. Preserve	Enable S3 server access logging; capture current bucket policy	S3
5. Eradicate	Remove offending bucket policy; re-enforce SSE-KMS requirement	S3 / KMS
6. Assess	Determine if data accessed: check S3 access logs and CloudTrail	S3 / CloudTrail

7. Recover	Validate encryption on all objects; confirm private access only	S3 / KMS
8. PIR	How did the bucket become public? Policy drift? Manual change?	-

EC2 Instance Compromise

Step	Action	AWS Service
1. Detect	CPU > 80% sustained alarm; NetworkOut spike; GuardDuty finding	CloudWatch
2. Identify	SSH to instance; inspect processes, cron jobs, open connections	EC2 / VPC Flow Logs
3. Contain	Swap Security Group to isolation SG (deny all); do not terminate yet	EC2 / Security Groups
4. Snapshot	Create EBS snapshot immediately for forensic preservation	EC2 / EBS
5. Eradicate	Terminate compromised instance; rebuild from clean, patched AMI	EC2 / AMI
6. Scan	Inspect other EC2 instances for same indicators of compromise	EC2 / Inspector
7. Recover	Deploy clean instance; verify SG rules; restore from clean backup	EC2 / S3
8. PIR	Determine entry point: public SSH? Outdated AMI? App vulnerability?	-